

Security+ 2.5 · Mitigation Techniques

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.5** —
Mitigation Techniques (6:51) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Mitigation techniques are layered defenses to reduce risk. They include patching (often the most neglected basic defense), encryption (protecting data at rest and in transit), monitoring/EDR (detect and respond), least privilege (minimal access), backups (recovery), training (human factor), and compensating controls (when ideal controls are not feasible).

High-Yield Core Concepts Tested on Exam

- Patching: the most basic and often neglected defense; most breaches exploit known vulnerabilities.
- Least privilege: users and systems get only the minimum access necessary.
- Defense in depth: layer multiple controls; never rely on a single solution.
- Compensating control: an alternative measure when the ideal control cannot be implemented.
- Encryption, monitoring/EDR, backups, and training are essential layers.

Exam Tips & Classic Scenarios

- 'reduces impact but doesn't eliminate vulnerability' = compensating control.
- 'minimum necessary access' = least privilege.
- 'layered defenses' = defense in depth.

Typical Exam Scenario: An industrial control system cannot be patched due to compatibility issues. The company isolates it on a separate network segment and monitors it closely. This is a compensating control.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.5 — Mitigation Techniques)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Giving each user ONLY the minimum access they need for their role is:

- A)** Least privilege
- B)** Separation of duties
- C)** Job rotation
- D)** Geographic need-to-know

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. Purchasing cyber insurance to cover the loss from an attack is which risk response?

- A) Accept the risk**
- B) Avoid the risk**
- C) Transfer the risk**
- D) Mitigate the risk**

4. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Patching: the most forgotten basic defense (most breaches were known patches)'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Patching: the most forgotten basic defense (most breaches were known patches)...**
- D) Allow shared access among administrators using generic credentials**

5. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Least privilege: each person only the minimum.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Least privilege: each person only the minimum...**

6. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Defense in depth: never 1 solution — stack them.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Defense in depth: never 1 solution — stack them...**

7. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'reduces impact but doesn't eliminate vulnerability' = compensating control. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'reduces impact but doesn't eliminate vulnerability' = compensating control
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.5) exam, an analyst evaluates the following technical requirement: 'Scenario: 'industrial system cannot be patched; company isolates and closely monitors it' = compensating control.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Scenario: 'industrial system cannot be patched; company isolates and closely monitors it' = compensating control.

9. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Patching: the most forgotten basic defense (most breaches were known patch)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Patching: the most forgotten basic defense (most breaches were known patch)...

10. Corporate scenario (Mitigation Techniques): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Least privilege: each person only the minimum'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Least privilege: each person only the minimum...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Least privilege.

✓ **Why it is correct:** The correct answer is 'Least privilege'. The principle of least privilege determines that each user, process, or system should be granted only the permissions strictly necessary to perform its functions, and nothing more. In the information security context, this reduces the attack surface and limits the impact of a compromise. For example, a user in the finance department should not have access to human resources files. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.1), lists least privilege as a fundamental security principle. The question describes exactly this definition: giving each user only the minimum access they need for their role.

✗ **Why the others are wrong:**

- *Separation of duties:* Separation of duties is a control that divides a critical task into steps performed by different people, so that no single person has total control over the process. For example, the person who approves a payment cannot be the same person who executes it. This prevents fraud and errors, but it does not refer to granting minimum access per user; instead, it distributes responsibilities. The question is about individual minimum access, not task division.
- *Job rotation:* Job rotation is the practice of periodically moving employees between different roles to detect fraud, reduce monotony, and train staff. It has no relation to the principle of granting only necessary access. Job rotation is an internal risk mitigation strategy, but it does not define each user's privilege level.
- *Geographic need-to-know:* Need-to-know is a security principle that restricts access to information only to those who need it to perform a specific task. However, 'geographic need-to-know' is not a standard term in the CompTIA Security+ certification. The concept of need-to-know is often associated with least privilege, but the expression 'geographic' adds a location restriction that is not present in the classic definition. The question does not mention geographic restriction, only functional minimum access. Therefore, the alternative is imprecise and does not correspond to the correct technical term.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST

CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) C — Transfer the risk.

✅ **Why it is correct:** The correct answer is: Transfer the risk. In the Risk Management domain of CompTIA Security+ SY0-701, risk responses include avoid, mitigate, transfer, and accept. Risk transfer occurs when the organization shifts the financial responsibility for a risk to a third party, typically through cyber insurance, outsourcing contracts, or indemnification clauses. By purchasing cyber insurance, the company pays a premium so that the insurer covers losses resulting from attacks, such as recovery costs, regulatory fines, extortion, and civil liability. It is important to note that transfer does not eliminate the risk itself (the attack can still occur), but transfers the financial impact. The organization must still maintain security controls to manage the probability and residual impact.

❌ **Why the others are wrong:**

- *Accept the risk*: Accepting the risk means recognizing the existence of a risk and deciding not to take any action to mitigate or transfer it, usually because the cost of mitigation exceeds the benefit or because the risk is considered acceptable within the organization's risk appetite. Purchasing insurance is not accepting the risk, as it involves an active action of financial transfer. Acceptance is passive and does not involve third parties.
- *Avoid the risk*: Avoiding the risk means eliminating the activity or process that generates the risk. For example, disabling a vulnerable service or prohibiting the use of USB devices. Purchasing insurance does not avoid the risk; the activity continues to exist and the attack can still occur. Avoidance is a behavior change to eliminate exposure, while insurance deals with financial consequences.
- *Mitigate the risk*: Mitigating the risk means implementing controls to reduce the probability or impact of an incident. Examples include firewalls, encryption, awareness training, and backups. Purchasing insurance does not reduce the probability of an attack nor the technical impact; it only financially compensates for losses. Therefore, it is not a mitigation measure, but a transfer.

4) C — Implement the corresponding solution: Patching: the most forgotten basic defense (most breaches were known patches)....

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Patching is the most forgotten basic defense; most breaches exploited known vulnerabilities that had patches available. Implementing a robust patch management process is essential to mitigate known exploits.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Least privilege: each person only the minimum....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Least privilege: each person only the minimum. The principle of least privilege grants users only the minimum access rights necessary to perform their job functions, reducing the attack surface and limiting the potential damage from compromised accounts.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Defense in depth: never 1 solution — stack them....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Defense in depth: never 1 solution — stack them. Defense in depth is a layered security approach that uses multiple overlapping controls to protect assets. The correct action is to implement the corresponding layered defenses.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'reduces impact but doesn't eliminate vulnerability' = compensating control.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): 'reduces impact but doesn't eliminate vulnerability' = compensating control. A compensating control is an alternative measure that provides equivalent protection when the primary control cannot be implemented, reducing risk but not fully removing the vulnerability.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Scenario: 'industrial system cannot be patched; company isolates and closely monitors it' = compensating control..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Scenario: 'industrial system cannot be patched; company isolates and closely monitors it' = compensating control. A compensating control is an alternative safeguard implemented when a primary control cannot be applied, providing equivalent risk mitigation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: Patching: the most forgotten basic defense (most breaches were known patch)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Patching: the most forgotten basic defense (most breaches were known patch). Patch management is a critical preventive control that involves identifying, acquiring, testing, and applying updates to operating systems, applications, and firmware to remediate known vulnerabilities. Many successful breaches exploit vulnerabilities for which patches were already available, highlighting the importance of timely patching. This control reduces the attack surface and prevents exploitation.

✗ **Why the other options are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Least privilege: each person only the minimum....

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Mitigation Techniques): Least privilege: each person only the minimum. The principle of least privilege dictates that users are granted only the minimum levels of access—or permissions—necessary to perform their job functions, reducing the attack surface and limiting potential damage from compromised accounts.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.